

AI GOVERNANCE & COMPLIANCE PACKAGE REPORT

Privacy & Secure Operations

Insurance Claims Triage AI (ClaimsTriage) v2.4

Controller	Meridian Health Partners Ltd.
Document Reference	MHP-AI-GOV-2026-PKG01
Effective Date	3 July 2026
Prepared By	AI Governance Lead
Audience	Regulatory readiness audit panel; Executive Risk Committee
Classification	Internal Restricted — Confidential Regulatory Audit Material
Supporting Artifacts	RoPA Article 30 register · DPIA mitigation plan · De-identification comparison matrix · Transformer attack surface report · Defence-in-depth control checklist · Patch-vs-retrain decision matrix · Emergency rollback plan · Unified risk disposition register

1. Executive Summary

AUDIT READINESS VERDICT	NOT READY IN CURRENT STATE — remediation required before audit
PROJECTED POSITION AT AUDIT	READY WITH CONDITIONS, achievable by 31 July 2026 if the conditions below execute on schedule and OD-03 resolves favourably

1.1 Why not “Ready with Conditions” today

The system under assessment is Insurance Claims Triage AI (ClaimsTriage) v2.4, the sole pre-authorization screening layer for approximately 4,200,000 claims per day with no parallel fallback, in production since January 2026. The Risk Disposition carries twenty open risks, four of them CRITICAL. A verdict of ready — in any form — while four critical items stand open would not survive the first hour of the audit, and stating it would cost this function more credibility than the findings themselves.

Two of the four are not control gaps that a remediation window closes. They are questions about whether the processing is lawful and whether a regulatory obligation has already been missed:

- RSK-04 — the Article 22 position is unevidenced. The package asserts that outputs influence but do not solely determine claim outcomes. Nothing measures whether the human review that claim rests on is meaningful.
- RSK-03 — no Article 33 breach assessment was performed on the ~1,200 adversarial queries that completed the transformer stack during incident MDC-2026-8891. The 72-hour notification clock ran from the alert and has already expired.

Both are answerable. Neither is answered. Until they are, the honest position is that Meridian cannot demonstrate the lawfulness of its own processing, nor demonstrate that it has met a notification obligation that may already have fallen due.

1.2 Why not a pause recommendation

Pausing is not costless and should not be recommended reflexively. ClaimsTriage is the sole pre-authorization screening layer for approximately 4,200,000 claims per day with no parallel fallback; suspending it stops claim adjudication for the entire book rather than degrading it. The harm of a pause is immediate, certain and borne by policyholders awaiting settlement.

Against that, every critical finding has an identified control, a named owner and a deliverable date, most within days. The two most exploitable — RSK-01 and RSK-05 — close within 24 and 72 hours

respectively. A remediation order is proportionate to a deployment whose defects are known, owned and closing. A pause is proportionate to one whose defects are not.

That balance changes if OD-03 resolves adversely. See 1.5.

1.3 Top three remediation priorities

Drawn from the Risk Disposition in Section 5, not generated independently.

Priority	Risk	Owner / Date	Why it ranks here
1	RSK-03 — Article 33 breach assessment absent	Lead Data Privacy Officer 6 July 2026	The only item that worsens with delay rather than merely persisting. Awareness dates from the alert; if the incident was notifiable, the 72-hour deadline has already passed and the sole remaining mitigation is prompt late notification with documented reasons. Every day it stays unassessed makes that explanation harder.
2	RSK-01 — Unvalidated transactional output dispatch	Application Security Lead 4 July 2026	The most severe verified finding (ADV-03, CRITICAL) and the most immediately exploitable. It defeats the human review trigger — the same safeguard RSK-04 concerns — and it is deliverable inside its 24-hour SLA because it is an interposed validation layer requiring no retraining.
3	RSK-04 — Article 22 position unevidenced	AI Governance Lead 17 July 2026	The verdict-determining item. It does not merely add risk; it decides whether the deployment's central legal claim holds. No other item can change the audit outcome in both directions.

CVE-2025-XXXX (RSK-02) is the largest single exposure in the package and is deliberately not in the top three. Its response path is decided, its patch executes same-day, and its retrain is under a signed risk acceptance with four compensating controls. It requires execution, not decision. The three above require decisions that have not yet been made.

1.4 What the package establishes

The analysis was conducted against a source pack whose artifacts contradicted one another on the CVE identity, the rollback target, the accuracy thresholds, the DPIA gap set and the Article 9 classification. Thirteen such defects were corrected before analysis began; they are recorded in Appendix C and in each artifact's change log rather than silently absorbed.

Finding	Figure	Significance
Processing activities registered	10	Six were previously unregistered, including multi-format medical document ingest, which the architecture specification names as a Stage 1 input.
Registered activities involving Article 9 data	10 of 10	There is no low-sensitivity remainder of this deployment to which lighter controls could be applied.
Defence-in-depth compliance	25.0%	Restated from a reported 55.6%. The posture did not deteriorate — it was measured against a control set omitting the three controls this deployment most needs.
Adversarial exploits verified	3	One CRITICAL, one HIGH, one MEDIUM. The CRITICAL bypassed human review triggers.
Adversarial queries reaching production	~1,200	Executed through the full transformer stack during a single incident. Never forensically analysed.
DPIA gaps identified	7	Five true gaps, two present-but-weak. Three were found only by testing the DPIA's own risk register for completeness.
Open risks	20	Four CRITICAL, eight HIGH, eight MEDIUM. Zero orphan findings across 46 upstream items.

1.5 The condition that would change this verdict

OD-03 — measured human review	If instrumentation shows that human review of flagged claims is substantive and that reviewers hold and exercise authority to overturn model outputs, the Article 22 position holds, RSK-04 closes, and the projected position at audit is Ready with Conditions. If it shows review is nominal, Article 22(1) applies to automated decisions producing significant effects on special category data. Article 22(4) then restricts the available grounds and Article 22(3) safeguards must be demonstrated, none of which is currently documented. In that case the deployment is processing Article 9 data through automated decision-making without a demonstrable lawful basis, and the appropriate recommendation becomes a deployment pause pending remediation rather than continued operation under conditions. This report does not predict the answer. It records that the answer is not known, that it is knowable within two weeks, and that the deployment has operated for six months without it.
--------------------------------------	---

Signed: AI Governance Lead, Meridian Health Partners Ltd. — 3 July 2026

2. GDPR Compliance

2.1 Processing scope and legal basis pairing

This section describes the same deployment assessed throughout: Insurance Claims Triage AI (ClaimsTriage) v2.4. The Article 30 register records ten processing activities for it. The supplied draft recorded four. Six were added during this review: supporting medical documentation ingest, RAG knowledge base retrieval, the high-risk human review queue, inference telemetry logging, the training corpus export to NovaTriage Analytics Ltd., and the separation of live triage processing from training reuse, which the draft had collapsed into one record.

Every one of the ten activities involves Article 9 special category data. There is no low-sensitivity remainder of this deployment to which lighter controls could reasonably be applied, and the security posture in Sections 3 and 4 should be read against that fact.

Record	Activity	Article 6 basis	Art 9	Article 9 condition
P-01	Live claim narrative processing (operational triage)	6(1)(b) contract; 6(1)(f) third parties	Yes	9(2)(g) substantial public interest — insurance
P-02	Supporting medical documentation ingest	6(1)(b) contract	Yes	9(2)(g); genetic data where lab results include genetic testing
P-03	Narratives and documentation as training corpus	6(1)(f) legitimate interests	Yes	9(2)(g)
P-04	Self-reported demographic monitoring field	6(1)(a) explicit consent	Yes	9(2)(a) explicit consent
P-05	Automated triage output and clinical-gravity scores	6(1)(b) decision; 6(1)(f) retention	Yes	9(2)(g); Article 22(4) engaged
P-06	Historic adjuster notes as training corpus	6(1)(f) legitimate interests	Yes	9(2)(g)
P-07	RAG knowledge base retrieval at inference	6(1)(b) own records; 6(1)(f) corpus	Yes	9(2)(g)
P-08	High-risk human review queue	6(1)(b); Article 22(3) safeguard	Yes	9(2)(g)
P-09	Inference and prompt telemetry logging	6(1)(f) security, Recital 49	Yes	9(2)(g)
P-10	Training corpus export to NovaTriage Analytics Ltd.	6(1)(f) legitimate interests	Yes	9(2)(g)

Three classifications corrected against the supplied draft

Claim narratives (P-01). The supplied workbook contradicted itself — Tab 1 recorded Article 9(2)(g), Tab 2 and the scenario package recorded “No — N/A”. A system that ingests clinical narratives and medical documentation and determines clinical gravity processes data concerning health. Resolved to Yes. The contradiction alone would have failed the audit before its substance was reached.

Derived triage scores (P-05). Recorded as “No — derived internal operational sorting index”. A classification expressing clinical gravity, computed from health narratives and attached to an identified policyholder, reveals health status; inferred special-category data is special-category data. Reclassified to Yes, and presented as a reasoned position because it is the more contestable of the corrections.

Historic adjuster notes (P-06). Recorded as “Conditional — post-redaction review required”. Article 9 admits no conditional state. Redaction is a minimisation control, not a basis for de-flagging, and NER false negatives are a live residual risk at 2.3, so completeness cannot be assumed. Reclassified to Yes, with redaction recorded as the control.

The Article 6 basis for claim narratives also moved from 6(1)(f) to 6(1)(b). Reaching for legitimate interests where contract necessity squarely applies imports an Article 21 objection right into a process the controller cannot decline to perform.

Two structural completeness findings

Article 30(1) content. The supplied template omitted controller and DPO contact details (30(1)(a)), transfer safeguards documentation (30(1)(e)) and a general description of technical and organisational security measures (30(1)(g)). All three are added. The security-measures omission was the most consequential — nothing connected the defence-in-depth posture assessed in Sections 3 and 4 to the processing it protects. That column now records applied controls and known deficiencies at this date, because a register listing only what works, when six controls are non-compliant or partial, misstates the position it exists to record.

Article 9 field inventory. Naming “health data” as a category is not an Article 30 record. The register is supported by an inventory of twenty-five named elements, and that inventory surfaced two exposures the draft did not record.

— Claimants write freely, so narratives foreseeably contain Article 9 categories the deployment never solicits: mental health, pregnancy and maternity, substance use, sexual orientation arising in the course of describing a related condition, religious belief where a treatment was declined on that basis, and trade union membership in occupational injury claims. No control targets unsolicited special-category disclosure — the NER pipeline is tuned for direct identifiers. Tracked at RSK-19.

— A category of data subject was absent entirely: dependants, beneficiaries, treating clinicians, employers and witnesses named within narratives. Their health data is processed with no consent, no notice and no realistic Article 14 route. Article 14(5)(b) disproportionate-effort relief must be documented rather than assumed. Tracked at RSK-15.

2.2 DPIA gap analysis and remediation plan

The five-step gap-detection methodology was applied: enumerate Section 3 risks, map Section 4 mitigations, flag unmitigated risks as True Gaps, test existing mitigations for a named control, owner, effectiveness criterion and cadence, and complete an entry for each.

A sixth step was added, and it produced three of the seven gaps. Steps 1 to 5 compare two lists and can only find gaps between them. A risk the DPIA author never identified in Section 3 has no Section 4 entry either, and the methodology as written is structurally blind to it. Section 3 was therefore re-tested for completeness against the deployment as described in the scenario package.

Ref	Gap	Type	Owner	Tracked at
GAP-01	Intermediate transcript cache retention	Present-but-Weak	Data Engineering Lead	RSK-16
GAP-02	Article 9 training corpus crossing the trust boundary	True Gap	Principal AI Architect	RSK-07
GAP-03	Access control over high-risk flagged claim narratives	True Gap	Chief Information Security Officer	RSK-11
GAP-04	Purpose limitation between operational triage and retraining	Present-but-Weak	Lead AI Infrastructure Engineer	RSK-17
GAP-05	Meaningful human review asserted but unevidenced	True Gap — added	AI Governance Lead	RSK-04
GAP-06	No Chapter V determination for cross-border transfers	True Gap — added	Lead Data Privacy Officer	RSK-08
GAP-07	No objection route or third-party notice for secondary use	True Gap — added	Lead Data Privacy Officer	RSK-15

GAP-05 is the most consequential entry

Every other gap concerns the security or governance of data within a lawful processing operation. GAP-05 concerns whether the operation is lawful at all.

The Article 22 position rests on the proposition that model outputs influence but do not solely determine claim outcomes, because a human reviews high-risk cases. Nothing evidences it. Set against that: the system is the sole pre-authorization screening layer with no parallel fallback; it dispatches automated transactional instructions rather than recommendations; and red-team testing bypassed routing to human review in 14.2% of adversarial variations.

The control instruments the review queue for review rate, override rate and median time-on-record, publishes a reviewer authority matrix confirming adjudicators may overturn any output without escalation and are not penalised for doing so, and establishes an override floor below which the review step is presumed nominal and the Article 22 position re-opens rather than being assumed to hold. Tracked at RSK-04.

A technical correction to an inherited control

CORRECTION	The scenario package's mitigation for cross-boundary export specified differential privacy transformations applied to the historical claim corpora prior to export. That control cannot work as described. DP-SGD perturbs gradients during backpropagation — it is a property of a training run, not a transformation applicable to a dataset and then shipped. Under the original wording, the largest privacy exposure in the deployment would have been recorded as mitigated while remaining wholly unprotected. That is a worse position than an open gap, because an open gap is visible. The controls are re-pointed: masking protects the export, DP-SGD protects the model. Implementation tracked at RSK-07 and RSK-09.
-------------------	---

Two residual risks are closed by no listed control and are carried into Section 5 rather than presented as resolved: the exported corpus remains personal data in the vendor's hands whatever masking is applied (RSK-07), and the Article 22 position remains unverified until the first review-rate measurement is taken (RSK-04).

2.3 De-identification recommendation and residual risk memorandum

RECOMMENDATION	Hybrid — clinical NLP-NER token masking applied to the corpus before export, combined with Differential Privacy (DP-SGD) applied to the model training run.
-----------------------	--

Two distinct exposures, and no single technique addresses both. Corpus confidentiality: a dataset of Article 9 clinical narratives leaves Meridian's trust boundary onto a third party's infrastructure, so what protects it must operate on the exported artefact. Model memorisation: a large language model trained on clinical narratives can reproduce training text and is vulnerable to membership inference, which for a health corpus discloses the condition by implication, so what protects against that must operate on the training process. Pairing them is not redundancy — they defend different objects.

Why this fits this deployment specifically

- The corpus is unstructured clinical prose, not tabular records. This removes K-anonymity from consideration entirely: generalisation and suppression are defined over structured quasi-identifier columns and there is nothing here to generalise. It also bounds what masking achieves, since identifying information is distributed through the prose rather than isolated in fields.
- The model must retain clinical semantics to function. ClaimsTriage classifies clinical gravity, so every technique that flattens clinical detail degrades the thing the system exists to do — and the accuracy floor is contractual: 91.0% TPR against a current 94.2%. There is 3.2 points of headroom, and de-identification spends some of it.
- The corpus crosses a trust boundary. This is what makes an export-surviving control mandatory. Were training performed in-house, DP-SGD with strong access control would be defensible; it is not once the data sits where Meridian cannot observe it.

Token-based pseudonymisation was rejected as a primary control: the mapping key exists and narrative context remains structurally intact, so it fails the EDPB linkability test on its own terms. K-anonymity was rejected as designed for tabular microdata, and because its outlier suppression would systematically remove the rare presentations that matter most clinically.

What this recommendation does not claim

The output is not anonymous data. NER-masked narratives remain personal data under Article 4(5) and Recital 26: means reasonably likely to be used for re-identification still exist, because the quasi-identifiers are in the prose and cannot be removed without destroying utility. The corpus is pseudonymised to a high standard and the full weight of the GDPR continues to apply to it.

This matters practically. Because the corpus is not anonymised, the export remains a transfer of personal data, and the Article 28 processing agreement and the Chapter V determination carry the protection that

de-identification cannot. Treating the masked corpus as anonymous would remove exactly those safeguards at the moment they are most needed.

Nor does DP-SGD render the model anonymous. It bounds membership inference advantage by a stated epsilon; it does not reduce it to zero, and a weak epsilon bounds very little. The guarantee is only as strong as the budget, which is why the budget must be documented and accounted cumulatively rather than described as “differential privacy applied”. This paragraph replaces the assertion in the supplied template that differential privacy satisfies the EDPB anonymisation tests and provides a legally defensible stance for exporting data — a claim that would not survive challenge.

Residual risks stated for acceptance

Ref	Residual risk	Rating	Accepting owner
R-DEID-01	Semantic re-identification via narrative quasi-identifiers	Medium	Lead Data Privacy Officer — RSK-12
R-DEID-02	Utility and fairness degradation on long-tail presentations	Medium	Principal AI Architect — RSK-14
R-DEID-03	NER false negatives leaving identifiers unmasked	Medium	Principal AI Architect — RSK-13
R-DEID-04	Corpus remains personal data in the vendor's hands	Medium	Lead Data Privacy Officer — within RSK-07
R-DEID-05	Epsilon budget exhaustion across successive retrains	Low–Medium	Principal AI Architect — RSK-20

Two deserve emphasis. R-DEID-02 is a fairness exposure, not only a utility one: DP noise disproportionately degrades accuracy on classes with few training examples, so the claimants with the least common presentations receive the least reliable triage in a system governing access to settlement. R-DEID-05 fails silently — the CVE-2025-XXXX remediation requires an unscheduled retrain consuming privacy budget outside the planned schedule, and without cumulative accounting successive retrains erode the guarantee until DP-SGD is present in the configuration but meaningless in effect.

All five are carried as discrete tracked line items in Section 5. A residual risk stated in the de-identification evaluation and absent from the risk disposition is an orphan finding — the specific cross-referencing failure that evaluation's own audit note warns causes audit failure.

2.4 Open determinations affecting the GDPR position

Ref	Question	What turns on it
OD-01	Main establishment and lead supervisory authority	Article 9(2)(g) is not self-executing. It requires a named Member State legal provision and an appropriate policy document — the condition relied on for eight of ten records.
OD-02	Country of establishment of NovaTriage Analytics Ltd.	Decides whether Chapter V applies at all. “Ltd.” is used in both the UK and Ireland and no country is recorded. Corpus export is suspended pending the answer.
OD-03	Measured review rate, override rate, reviewer authority	The determination that can change the audit verdict. See 1.5.
OD-04	Azure region and Microsoft sub-processor chain	Telemetry derived from Article 9 narratives, including embedding vectors, flows through a chain never enumerated — a transfer route easy to overlook because monitoring is not usually thought of as a transfer.
OD-07	Is self-reported ethnicity a model input feature or a monitoring dimension?	The draft records both purposes. If a training feature in a system that prioritises claims, the deployment carries direct discrimination risk under Article 5(1)(a) and engages Article 22(4). If used only to test outputs for disparate impact, it is a fairness safeguard. The two cannot both stand.

The RoPA transfers column has been changed from “none identified at this stage” to UNDETERMINED across nine records, with the tenth recorded as a known transfer with an outstanding mechanism. The original entry records that no assessment was performed. It is not a finding, and presenting it to an auditor as one is the kind of unforced error that converts a remediation order into a pause directive.

3. Model Security Posture Assessment

3.1 Transformer attack surface mapping

Five distinct attack surfaces exist in the ClaimsTriage architecture. Three are designated priority surfaces, ordered by the severity the adversarial engagement assigned. All five are ranked, so the selection can be checked rather than taken on trust.

AS-04 — The inference output layer: decoding and outbound transactional dispatch · CRITICAL

Stage 4. From logit distribution through token selection to serialisation and dispatch of transactional instructions into the Automated Claims Adjudication Queue, the High-Risk Human Review Queue and Medical Underwriting Systems.

Threat vectors: adversarial instructions surviving the decoder serialised and dispatched as transactional calls to backend financial queues without structural verification; unreviewed model output executing unauthorised state changes; routing manipulation directing high-risk files into standard queues, defeating human-in-the-loop oversight at the final hop.

Control coverage: C2.2 Non-Compliant (status corrected) and C2.5 Non-Compliant. Directly evidenced by red-team finding ADV-03 (CRITICAL): exploiting token logit distributions forced the output layer to append standard-processing routing tags to high-risk files, bypassing human review triggers. The AML assessment records the same outcome reached from the claim form at a 14.2% success rate.

AS-01 — The model API endpoint: public claim ingestion and tokenization boundary · HIGH

Stage 1. The public-facing web claim interface through to the tokenizer — the only surface reachable by an unauthenticated member of the public.

Threat vectors: token-splitting and character-obfuscation strings defeating signature matching; malformed multi-byte Unicode homoglyphs bypassing length filters and forcing out-of-vocabulary indices; long-form sequences engineered for context-window exhaustion; malicious content in uploaded PDF medical documents, which enter through a parsing path distinct from the text field and are subject to the same absent controls.

Control coverage: C1.1 Partially Compliant, C1.3 Non-Compliant, C2.1 Partially Compliant. This is the only surface carrying both adversarial-test and production-telemetry evidence: ADV-01 (HIGH) proved the gateway bypass achievable, and alert MDC-2026-8891 proved it is being attempted at volume against production.

Rated on direct impact. An earlier draft rated this CRITICAL by crediting its enablement of AS-03 and AS-04; that inflates every upstream surface to the severity of the worst thing downstream of it, and the red team's discipline is adopted instead.

AS-03 — The shared context window: attention layer and RAG assembly boundary · HIGH

Stage 3. Where untrusted claimant text, retrieved policy and clinical documents, and system routing instructions are assembled into a single context window. Control coverage: C2.4 Non-Compliant and absent from the supplied checklist entirely, C2.1 Partially Compliant, C2.5 Non-Compliant.

Two distinct entry paths, one surface. The AML assessment records instruction override at 14.2% via the claim form. Red-team finding ADV-02 (MEDIUM) compromised the same surface through the RAG ingestion channel, forcing the attention window to leak the system prompt.

Two surfaces ranked below the priority set

AS-05 — the training data pipeline (HIGH). Ranked fourth on attacker feasibility alone; its impact equals any surface above it. Exploitation requires vendor-feed or build-environment access, not the public boundary. Its impact is systemic rather than per-transaction: a poisoned corpus misclassifies every input matching an attacker-controlled pattern for the life of that model version. AS-01 through AS-04 compromise transactions; AS-05 compromises the classifier. Controls C3.1, C3.3 and C3.4 all attach and all are Non-Compliant. Assessed in Section 4, where CVE-2025-XXXX is handled.

AS-02 — the vector representation space (MEDIUM). Not independently reachable; closing AS-01 substantially closes it, and its exploit degrades classification rather than hijacking it. Retained because MDC-2026-8891 is classified “Anomalous Token Sequences & Repeated High-Entropy Inputs” — this surface's exploit signature. It appeared on no map in the source pack.

The structural correction to the supplied map

The supplied Transformer Architecture report labelled the Stage 3 attention annotation “the training data pipeline”. RAG retrieval happens at inference, against a live claim, reachable by anyone who can submit one; corpus ingestion happens offline, during a build. Different attacker, different window, different controls. The consequence of merging them: the deployment's actual training pipeline had no surface of its own, which is why a training-time CVE appears in no attack surface map anywhere in the source pack.

3.2 Adversarial test findings and hardening priorities

ID	Verified exploit	Severity	Surface	Disposition
ADV-03	Output token hijacking and queue redirection — logit distribution exploitation forced standard-processing routing tags onto high-risk files, bypassing human review triggers	CRITICAL	AS-04	RSK-01 · HP-01
ADV-01	Direct prompt injection via obfuscated medical narrative strings — token-splitting bypassed web gateway filters, allowing system instruction overrides	HIGH	AS-01	RSK-05 · HP-02
ADV-02	Indirect prompt injection via vector DB / RAG ingestion — adversarial formatting in historical claims repositories forced the attention window to leak the system prompt	MEDIUM	AS-05 write → AS-03 read	RSK-10 · RSK-06 · HP-03

ADV-02's surface attribution is corrected. The red team recorded it against “the training data pipeline”. The exploit has two halves: a write into the claims repository — a corpus ingestion event, control C3.1 — and a read at inference, where poisoned content enters the context window, control C2.4. The attacker writes once and the payload is read back later, against unrelated claims and unrelated claimants. Neither control substitutes for the other, and a map with one surface can only name one of them.

A methodology note on the rubric

The rubric returns two different answers for the same finding, and the package should state which method governs. ADV-02 is system prompt extraction. Section 2 of the rubric classifies by consequence alone and lists prompt leakage under HIGH. Section 3 crosses feasibility with impact, placing prompt leakage in the Medium Impact column — so at the low feasibility of write access to internal repositories it returns LOW to MEDIUM.

The red team applied Section 3, and its three ratings are internally consistent with that matrix. This package follows Section 3 throughout and records the choice, so a reviewer arriving at a different figure from Section 2 can see why rather than treating it as an error. Where they disagree, Section 3 governs: feasibility is a real constraint on risk, and a classification ignoring it over-rates every theoretical finding.

Hardening priorities

The adversarial engagement isolated two strategic priorities, carried forward unchanged. A third is added. The red team's selection is not the obvious one and is worth stating: it prioritised the two ends of the attack chain — the boundary an attacker must enter through, and the boundary where damage lands — rather than the attention layer in the middle where the instruction override actually occurs. AS-03 is the model's own reasoning, and no deterministic control can be placed inside attention. AS-01 and AS-04 are the two points where a control can refuse a request outright. Harden what can be enforced, then mitigate what can only be influenced.

Priority	Control	SLA	Position
HP-01 AS-04	Pydantic output data contracts and structural validation between decoder and dispatch, failing closed to human handling. Separation of response content from routing control tokens.	24 hours CRITICAL	Deliverable in window. An interposed validation layer changes no model behaviour and carries no regression exposure against the accuracy floor. Owner: Application Security Lead.
HP-02 AS-01	Input guardrail layer ahead of the tokenizer — token-length caps, Unicode normalisation with homoglyph folding, semantic pre-classification. WAF extended with OWASP Top 10 for LLM signatures. Same controls applied to the PDF parsing path.	72 hours HIGH	Deliverable in window. Owner: Principal AI Engineer.

Priority	Control	SLA	Position
HP-03 AS-03	Cryptographically random per-request delimiters around untrusted claimant text; explicit instruction hierarchy; RAG retrieval scope constrained to the claimant's own records.	72 hours HIGH	NOT deliverable in window — see below. Owner: Principal AI Engineer.

The remediation window, stated rather than buried

Two of the three priorities meet their SLA without difficulty. HP-03 does not: context window encapsulation is a prompt architecture change requiring regression testing against a 4.2 million claim per day system with a 91.0% accuracy floor and 3.2 points of headroom. Seventy-two hours is not an honest estimate.

The supplied report template assigned model-security remediations target dates of 12 and 15 July against a 3 July package date — nine and twelve days out — with no acknowledgement that a rubric in the same package mandates 24 and 72 hours. A risk register that breaches the SLA of its own rubric is a finding an auditor makes in a single comparison.

Window	Action	Priority / Surface	Basis
24 hours	Pydantic output contracts and structural validation, failing closed; raised alerting on routing anomalies	HP-01 · AS-04	ADV-03 CRITICAL. SLA met.
24 hours	Interim compensating controls for HP-03: block known injection structural variants at input; force human review on every settlement-queue routing above a value threshold	AS-01, AS-03	Satisfies immediate-triage while the durable fix is built.
72 hours	Input guardrail layer; WAF extended with OWASP LLM signatures	HP-02 · AS-01	ADV-01 HIGH. SLA met.
7 days	Full context window encapsulation, after regression testing against the 91.0% TPR floor	HP-03 · AS-03	ADV-02. SLA exceeded by 4 days.
Throughout	Documented risk acceptance for the HP-03 interval, signed by the AI Governance Lead, recording residual exposure and compensating controls	AS-03	Rubric §4 traceability requirement.

One priority exceeds its SLA, by four days, for a stated engineering reason, with compensating controls in place and a named owner accepting the gap. That is defensible in front of an auditor. Nine days with no acknowledgement is not.

3.3 Defence-in-depth configuration gaps

Twelve controls assessed. Systemic compliance score: 25.0% — three compliant, two partially compliant, seven non-compliant. The supplied checklist reported 55.6% over nine controls. The posture did not deteriorate; it was previously measured against a control set that omitted the controls this deployment most needs. One status was corrected against primary sources (C2.2), three absent controls were added (C2.4, C2.5, C3.4), and one was downgraded on production evidence (C1.1).

Gap	Layer	Weak or missing control	Exposure	Severity	Tracked at
DID-02 (C2.2)	Output	No outbound JSON schema validation before transactional dispatch	Adversarial instructions surviving the decoder execute state changes in adjudication systems	CRITICAL	RSK-01
DID-05 (C2.5)	Output / Processing	No reconciliation of intended routing against actual queue placement	A successful routing bypass produces no signal; the system cannot evidence that human review occurred	CRITICAL	RSK-01
DID-01 (C2.4)	Processing	No structural encapsulation of untrusted input in the context window	Model cannot distinguish instruction from data; policy limits overridden, human review bypassed	HIGH	RSK-06
DID-03 (C1.3)	Input	WAF carries generic layer-7 rules only, no OWASP LLM signatures	Injection payloads are well-formed HTTP; nothing in a generic ruleset distinguishes hostile from legitimate	HIGH	RSK-05

Gap	Layer	Weak or missing control	Exposure	Severity	Tracked at
DID-09 (C2.1)	Input	Keyword blacklist only; no semantic anomaly detection	A blacklist enumerates known bad strings; the attack class is defined by intent. Live during the 14.2% result	HIGH	RSK-05
DID-08 (C1.1)	Input	Threshold-based per-source rate limiting; 45-minute demonstrated time-to-throttle	The observed attack came from an IP block; per-source thresholds are structurally defeated by distribution across one	HIGH	RSK-05
DID-04 (C3.1)	Data & Governance	No cryptographic hash-chain verification of corpus or RAG integrity at ingestion	No way to demonstrate the v2.4 corpus was untampered, so CVE-2025-XXXX cannot be excluded. Also the write-side control for ADV-02	HIGH	RSK-10
DID-06 (C3.3)	Data & Governance	No DP-SGD; no epsilon-delta budget	Membership inference and text memorisation over Article 9 narratives. Blocks the de-identification recommendation at 2.3	HIGH	RSK-09
DID-07 (C3.4)	Data & Governance	No signed model bill of materials	Advisory triage becomes manual archaeology under time pressure and may return no answer	MEDIUM	RSK-18

The structural finding

Four of nine gaps sit in a layer the AML security configuration report never examined. That report assesses Input, Processing and Output — the runtime inference path only. Training-time integrity, corpus provenance, differential privacy and supply-chain attestation have no place in its taxonomy and were never assessed.

That is where CVE-2025-XXXX lives, and it is also where the write-side control for ADV-02 lives. A reader of the AML report alone would conclude the deployment has three deficient layers; the checklist shows four, and the unexamined one carries both the CVE exposure and half of a verified exploit. A defence-in-depth review scoped to the inference path is not a defence-in-depth review.

Layer crosswalk

Required because this section uses the AML report's input/processing/output taxonomy while the checklist uses network/application/data-and-governance. Without it, findings here cannot be traced to the controls that produced them.

AML report layer	Verdict	Checklist controls	Net status
Input	Deficient	C1.1 Partial, C1.3 Non-Compliant, C2.1 Partial	Deficient — confirmed. All three fail against the same attack class for the same reason: each enumerates known-bad patterns rather than modelling intent
Processing	Deficient	C1.2 Compliant, C2.3 Compliant, C2.4 Non-Compliant (added)	Deficient — confirmed. The two compliant controls protect the network and observe the runtime; neither addresses prompt structure
Output	Deficient	C2.2 Non-Compliant (corrected), C2.5 Non-Compliant (added)	Deficient — confirmed. Verifying output is well-formed is not verifying it went where intended
(none)	NOT ASSESSED	C3.1, C3.2, C3.3, C3.4	3 of 4 Non-Compliant — the structural finding above

One control deserves credit rather than criticism. C2.3 real-time telemetry is Compliant and performed: it generated MDC-2026-8891. Detection is not prevention — the alert fired and 1,200 queries still completed — but telemetry is the reason this deployment knows about the exposure at all.

4. Operational Security and Telemetry Interpretation

4.1 Telemetry analysis — incident MDC-2026-8891

One high-severity alert appears in the 90-day Defender for Cloud window.

Alert ID / Severity	MDC-2026-8891 · High
Classification	Anomalous Token Sequences & Repeated High-Entropy Inputs Detected on Claims Inference Endpoint
Duration and source	4 continuous hours; automated scripts from an external IP block, targeting primary web text input fields
Signature	Patterns designed to induce context-window resource exhaustion and trigger application-layer routing bypasses
Mitigation	Network edge rate-limiting throttled source IPs after 45 minutes
Outcome	Approximately 1,200 adversarial queries executed through the entire transformer stack before mitigation

What it indicates

The alert classification maps onto three attack surfaces named in Section 3 at once, which is what makes it a chain rather than a probe. “Anomalous token sequences” is AS-01, the model API endpoint — the surface HP-02 addresses and the surface ADV-01 independently proved bypassable. “Repeated high-entropy inputs” is the exploit signature of AS-02, the vector representation space, which appeared on no attack surface map in the source pack: the deployment held telemetry evidencing a surface it had not mapped. “Application-layer routing bypasses” is the intended outcome at AS-03 and AS-04 — the same outcome ADV-03 achieved and the AML assessment measured at 14.2%.

No new surface is introduced here. Every element of this alert was named in Section 3 before the telemetry was read.

The escalation outcome, and what it actually demonstrates

Three controls were exercised, and their performance is not uniform.

- C2.3 real-time telemetry performed. The alert exists because this control works, and it deserves credit in a section otherwise full of failures.
- C1.1 rate limiting partially performed, and the timing is the finding. Forty-five minutes elapsed before throttling engaged. But the more revealing number is the arithmetic: 1,200 queries across the 45-minute pre-mitigation window averages roughly 27 requests per minute in aggregate — well below the configured 100-per-minute threshold, and far below it once distributed across an IP block. Whatever tripped the throttle, it was not these queries. The control fired on high-volume noise and never applied to the traffic that actually completed the stack.
- C1.3 LLM-aware WAF inspection did not perform, because it does not exist. This is the control that should have raised the alert in minutes on signature rather than in 45 on volume.

The question the source pack does not ask

NO ARTICLE 33 ASSESSMENT EXISTS	No forensic analysis was performed on the 1,200 queries that completed, and no Article 33 breach assessment exists. This is the most consequential gap in the operational security posture and it is entirely absent from the supplied package. Approximately 1,200 adversarial queries executed through the full transformer stack of a system whose two demonstrated failure modes are routing bypass (ADV-03, CRITICAL — Article 9 claims diverted from human review) and system prompt leakage (ADV-02, from a context window containing retrieved clinical records). Either outcome, if achieved, engages Article 4(12): the first as unauthorised alteration of processing, the second as a confidentiality breach of Article 9 data. Applying the red team's 14.2% rate to 1,200 queries yields roughly 170 potentially successful bypasses. That figure is a bounding illustration and nothing more — red-team payloads were purpose-built and tested under controlled conditions. The point is not the
--	--

	estimate. The point is that the actual number is unknown, is knowable only through forensic analysis that was never performed, and that zero is not the safe default. Article 33(1) requires notification within 72 hours of awareness unless the breach is unlikely to result in a risk. Article 33(5) requires every breach to be documented — including those assessed as not notifiable — with the facts, effects and remedial action. Neither the assessment nor the documentation exists. Even a well-founded conclusion of “no notifiable breach” would need to be written down, and it has not been.
--	--

Tracked at RSK-03 and ranked first in the remediation priorities, because it is the only item that worsens with delay rather than merely persisting.

Two determinations the alert record cannot support

OD-08 — was this red-team traffic? The adversarial engagement ran 15–30 June 2026; the alert falls inside the 90-day window. A pre-authorised engagement's traffic is normally excluded from alerting or annotated as such, and the package does neither. Both answers matter: if this was red-team traffic misclassified as an external attack, the detection is good news and the incident is not an incident; if it was genuine, an unknown actor was probing precisely the weaknesses the red team found, in the same period. An incident responder asks “is this us?” first. The package gives no answer.

OD-09 — is one alert the whole 90 days? The package describes “the last 90 days of alert summaries” and documents a single high-severity alert. Without the alert-volume baseline and the medium and low severity records, this incident cannot be placed in context: a one-off and the visible instance of a sustained pattern look identical when you have one data point.

Implications for current security posture

The incident demonstrates in production what Section 3 established from configuration review: the perimeter is not a security boundary for this deployment. Network isolation protects the subnet, and the attack arrived through the legitimate public claim interface. Edge rate-limiting responds to volume, and the attack's effective component was quiet. The only control positioned to distinguish a hostile claim narrative from a legitimate one is LLM-aware application-layer inspection, and it is Non-Compliant.

Detection is not prevention. Until HP-02 deploys the input guardrail layer and HP-01 deploys output validation, a repeat of this incident produces the same result with the same telemetry — the deployment would watch it happen again.

4.2 CVE-2025-XXXX — patch-versus-retrain decision

CVE / Component	CVE-2025-XXXX — NeuralCore Library v3.1.x–v3.4.x, gradient computation and weight initialization modules
Type / Score	Improper input validation in the gradient descent optimizer · CVSS v3.1 8.6 (High) · Scope Changed / Network · AC High · PR None
Exposure class	TRAINING-TIME. No effect on inference-time behaviour in models trained without exploitation.
Attack surface	AS-05 — the training data pipeline (Section 3.1)
Meridian exposure	ClaimsTriage v2.4 was trained six months ago on NeuralCore v3.3.2, inside the affected range. Training data was ingested from an external vendor over a network connection across a 72-hour window. Control C3.1 (cryptographic ingestion hashing) is Non-Compliant and has never existed, so no integrity evidence for that corpus is available.

The consequence is precise: the absence of C3.1 is what converts an advisory into an unfalsifiable exposure. Meridian cannot demonstrate the corpus was tampered with, and cannot demonstrate it was not. The production model must therefore be treated as potentially carrying an attacker-controlled backdoor.

Decision matrix, rescored

The supplied matrix was calibrated for an inference-time vulnerability. Two criteria change materially for a training-time exposure.

Criterion	Supplied	Rescored	Why
Speed to protection, patch-only	5.0	1.0	Patching the inference environment closes no exposure that has already occurred — the scenario package states this directly. Time-to-protection is not 24 hours; it is never.
Long-term robustness, patch-only	2.0	1.0	Patch-only does not “mask a deeper flaw”. It leaves a model that cannot be shown free of a backdoor running as the sole screening layer, indefinitely.
Strategy	Raw sum	Weighted score	Mandatory gates failed
S1 — Environment patch only	16	2.85	2 — EXCLUDED
S2 — Full retrain only	13	2.60	0
S3 — Hybrid: patch + retrain	19	3.90 — RECOMMENDED	0

Two methodological points, both fixing defects in the supplied matrix.

The recommendation is now the highest-scoring strategy. The supplied matrix recommended Hybrid at 4.05 while Patching Only scored 4.25, and reported a “Matrix Verification Score” of 2.3 — which was Retraining Only’s score. Three numbers, none agreeing with the verdict.

A mandatory gate test was added, because the weighted score alone gives the wrong answer. Note that S1 outscores S2 despite delivering no protection whatever: speed, disruption and cost together carry 0.65 of the weighting, so a fast, cheap, non-disruptive strategy ranks well even when it achieves nothing. S1 fails two knockout gates — it does not remove the exposure that already occurred, and it leaves Meridian unable to demonstrate to a regulator that the production model is free of a backdoor. A strategy failing a gate is excluded regardless of rank. The matrix is a decision aid, not the decision.

Business impact

Measure	21-day retrain	28-day retrain	Source
Claims processed by an unverifiable classifier	88.2 million	117.6 million	4.2m/day
Transaction value processed	\$7.67 billion	\$10.23 billion	× \$87 average

These figures state exposure scope, not expected loss. No loss is asserted and none may be inferred — the exposure is unproven. They state what is riding on the acceptance.

The rollback alternative. ClaimsTriage v2.3 operates at 90.4% TPR, 0.6 percentage points below the 91.0% contractual floor — a breach effective at cutover, not at end of day. The 3.8-point drop from v2.4 produces 159,600 additional manual review claims per day, accumulating to 3.35 million over a 21-day retrain window, which exceeds manual capacity by a wide margin and compounds daily.

THE TRADE BEING MADE	The hybrid path carries a large but unproven and probabilistic exposure. The rollback path carries a smaller but certain and immediate harm. Choosing hybrid is choosing probabilistic exposure over certain harm — a defensible trade, but only if recorded as a deliberate risk acceptance with compensating controls and a named owner, rather than presented as though it were cost-free. Accepting owner: Director of AI Production Infrastructure Operations, countersigned by the AI Governance Lead and the Chief Information Security Officer. Reviewed weekly during the retrain window and immediately on any shadow-comparator divergence alert. Tracked at RSK-02.
-----------------------------	---

A correction to the inherited compensating control

The scenario package specifies that during remediation “input layer filters will block all claimant submissions containing structural text variants associated with known backdoor triggers”. This control is not implementable as written. CVE-2025-XXXX causes misclassification of inputs matching a specific attacker-controlled pattern. If the corpus was poisoned, that pattern was chosen by the attacker and is unknown to us; the advisory publishes no indicators of compromise. A filter cannot block what cannot be

enumerated. Carried forward unexamined, it would have appeared in the package as a mitigation while providing nothing.

Ref	Control	Why it works where filtering does not
CC-1	Shadow comparator (primary). Run ClaimsTriage v2.3 in shadow against live traffic, scoring every claim and routing none. Alert on statistically significant divergence from v2.4 on identical input.	v2.3 was compiled on NeuralCore v2.9.1, outside the affected range — it is clean of this vulnerability. A backdoor is invisible to a filter because its trigger cannot be named, but visible as disagreement between a suspect model and a clean one on the same claim. This detects what cannot be filtered, using an asset the deployment already holds.
CC-2	Output distribution monitoring against the 90-day pre-incident baseline.	A backdoor routing attacker-pattern claims to automated approval shows as an unexplained shift in the automated-approval share, even when the trigger is unknown.
CC-3	Enhanced human review sampling on automated-approval routings, weighted to high-value claims.	Converts an undetectable classifier defect into a detectable review-disagreement signal.
CC-4	Patch the build environment to v3.5.0 within the 4-hour window; freeze training on the affected library; implement C3.1 before the retrain corpus is assembled.	Closes forward exposure, and ensures the replacement model can be demonstrated clean in a way v2.4 never can. Without ingestion hashing the retrained model inherits the same unfalsifiable position, and the next advisory produces the same crisis.

Note on the four-hour figure. The scenario package refers to a “4-hour engineering patch window” and the supplied report template describes an “accelerated 4-hour retraining pipeline”. These are not the same thing. Four hours is the library patch window; retraining takes 3 to 4 weeks. The template's phrasing would tell an auditor the model is clean by the end of the working day. It will not be.

Rollback conformance reference

A validated rollback procedure is in place: MHP-OPSC-RECOVERY-v2, satisfying gate G5 of the decision matrix. Target ClaimsTriage v2.3 on NeuralCore v2.9.1, 45-minute containerised redeployment, decision owner the Director of AI Production Infrastructure Operations. Four corrections were made to the inherited plan.

- It addressed CVE-2026-38291, a tokenizer vulnerability not applicable to this deployment. Rewritten against CVE-2025-XXXX.
- Target version corrected from “v1.4.2-stable” to v2.3; recovery time from 12 minutes to 45 minutes.
- The accuracy trigger was self-defeating. It fired below 92.5% while the rollback target operates at 90.4% — executing the rollback would immediately re-satisfy the condition mandating it. Corrected to 89.5%, set below the target's performance so reverting does not re-trigger.
- A third trigger was added, and it is the only one that can detect this CVE's harm. Triggers 1 and 2 detect degraded aggregate accuracy and known-signature exploitation; a targeted backdoor produces neither. Trigger 3 fires on shadow-comparator divergence. Without it, the deployment could be actively exploited throughout the retrain window with no trigger firing.

The 24-hour limit does not survive contact with this CVE. The inherited plan caps the rollback state at 24 hours “while patching is finalized” — framing that belongs to an inference-time vulnerability. If rollback is triggered here by confirmed exploitation or shadow divergence, returning to v2.4 is precisely what must not happen: v2.4 is the suspect artefact. The earliest safe return is the retrained replacement, 3–4 weeks away. An escalation path is now defined in the plan rather than left to be improvised on the day it fails.

One caveat is stated rather than glossed: v2.3 is clean of CVE-2025-XXXX, not clean generally. C3.1 has never existed, so v2.3's corpus provenance is as unverified as v2.4's. Rollback removes a specific known exposure, not the class of exposure.

5. Risk Disposition and Integration Consistency Statement

Part A — Unified Risk Disposition

Every open item, residual risk and outstanding action from Sections 2, 3 and 4 is aggregated here. No risk appears in this section that was not analysed in a preceding one, and no finding raised in a preceding section is absent without an explicit disposition. Full detail — control, effectiveness criterion and residual risk for each entry — is held in the Unified Risk Disposition Register (supporting artifact); this section carries the disposition view.

POSITION AT PACKAGE DATE	20 open risks: 4 CRITICAL, 8 HIGH, 8 MEDIUM. 46 upstream findings tracked, 33 open and 13 closed by correction during this review. Zero orphan findings.
---------------------------------	---

A.1 Open risk register

Risk ID	Severity	Risk statement	Source (earlier section)	Named owner	Target close
RSK-01	CRITICAL	Unvalidated transactional output dispatch enables queue redirection and human review bypass	\$3.1 AS-04 · ADV-03 · DID-02 · DID-05 · HP-01	Application Security Lead	4 Jul 2026
RSK-02	CRITICAL	Production model cannot be demonstrated free of a training-time backdoor (CVE-2025-XXXX)	\$4.2 CVE-2025-XXXX · AS-05 · DID-04	Director, AI Production Infrastructure Ops	Patch 3 Jul / Retrain 31 Jul
RSK-03	CRITICAL	No Article 33 breach assessment for the ~1,200 queries that completed the stack	\$4.1 MDC-2026-8891 · ADV-02 · ADV-03	Lead Data Privacy Officer	6 Jul 2026
RSK-04	CRITICAL	Article 22 position unevidenced — meaningful human review not demonstrated	\$2.2 GAP-05 · OD-03 · ADV-03 · DID-05	AI Governance Lead	17 Jul 2026
RSK-05	HIGH	Public ingestion boundary defeated by token-splitting and character obfuscation	\$3.1 AS-01 · ADV-01 · DID-03 · DID-08 · DID-09 · HP-02	Principal AI Engineer	6 Jul 2026
RSK-06	HIGH	Context window lacks structural encapsulation of untrusted input	\$3.1 AS-03 · ADV-02 · DID-01 · HP-03	Principal AI Engineer	10 Jul 2026
RSK-07	HIGH	Article 9 corpus crosses the trust boundary under an unworkable de-identification control	\$2.2 GAP-02 · R-DEID-04 · OD-02	Principal AI Architect / Lead DPO	17 Jul 2026
RSK-08	HIGH	No Chapter V transfer determination for any of ten processing activities	\$2.2 GAP-06 · OD-02 · OD-04	Lead Data Privacy Officer	17 Jul 2026
RSK-09	HIGH	No DP-SGD — membership inference exposure; blocks the de-identification recommendation	\$3.3 DID-06 · \$2.3 recommendation	Principal AI Architect	31 Jul 2026
RSK-10	HIGH	No cryptographic corpus ingestion integrity verification	\$3.3 DID-04 · ADV-02 · AS-05	Principal AI Architect	24 Jul 2026
RSK-11	HIGH	Unrestricted access to Article 9 content in the high-risk review queue	\$2.2 GAP-03	Chief Information Security Officer	31 Jul 2026
RSK-15	HIGH	No Article 21 objection route; no Article 14 notice for third parties in narratives	\$2.2 GAP-07 · \$2.1 third-party subjects	Lead Data Privacy Officer	31 Jul 2026
RSK-12	MEDIUM	Semantic re-identification via narrative quasi-identifiers in the exported corpus	\$2.3 R-DEID-01	Lead Data Privacy Officer	Each corpus freeze
RSK-13	MEDIUM	NER false negatives leaving direct identifiers unmasked	\$2.3 R-DEID-03	Principal AI Architect	Each corpus freeze
RSK-14	MEDIUM	DP noise degrades accuracy on long-tail presentations — a fairness exposure	\$2.3 R-DEID-02 · OD-07	Principal AI Architect	Each model release
RSK-16	MEDIUM	Intermediate transcript cache retention weakly controlled	\$2.2 GAP-01	Data Engineering Lead	17 Jul 2026
RSK-17	MEDIUM	Purpose limitation between operational triage and retraining unenforced	\$2.2 GAP-04	Lead AI Infrastructure Engineer	24 Jul 2026

Risk ID	Severity	Risk statement	Source (earlier section)	Named owner	Target close
RSK-18	MEDIUM	No signed model provenance attestation	§3.3 DID-07	Lead AI Infrastructure Engineer	31 Aug 2026
RSK-19	MEDIUM	Unsolicited Article 9 categories in free text with no targeted control	§2.1 Art 9 field inventory	Lead Data Privacy Officer	31 Aug 2026
RSK-20	MEDIUM	Epsilon budget exhaustion across successive retrains — silent failure mode	§2.3 R-DEID-05 · §3.3 DID-06	Principal AI Architect	Each training run

A.2 The four critical risks

Detailed here because the posture verdict in Section 1 rests on them.

RSK-01 — Unvalidated transactional output dispatch · Application Security Lead · 4 July 2026

Transactional output is dispatched to backend financial queues without structural validation, allowing adversarial instructions surviving the decoder to redirect high-risk claims away from human review and execute unauthorised state changes. Sources: AS-04, ADV-03 (CRITICAL), DID-02, DID-05, HP-01.

Residual after control: validation enforces schema conformance, not semantic correctness — a well-formed instruction to route a high-risk claim to standard adjudication still passes. Routing integrity reconciliation (C2.5) closes that remainder and is scheduled with the same control.

RSK-02 — Unverifiable training-time backdoor (CVE-2025-XXXX) · Director, AI Production Infrastructure Operations · patch 3 July, retrain 31 July 2026

ClaimsTriage v2.4 cannot be demonstrated free of an attacker-controlled backdoor. It was compiled on NeuralCore v3.3.2, inside the affected range, on a corpus ingested over a network connection with no integrity verification, and it operates as the sole screening layer with no parallel fallback. Sources: CVE-2025-XXXX, AS-05, DID-04, MHP-OPSC-RECOVERY-v2.

Residual after control — ACCEPTED AND SIGNED: for 3–4 weeks the deployment processes 88–118 million claims carrying \$7.67–10.23bn of transaction value through a classifier that cannot be demonstrated clean. The exposure is unproven and probabilistic; the rollback alternative is certain and immediate. Countersigned by the AI Governance Lead and the CISO, reviewed weekly and on any shadow-divergence alert.

RSK-03 — No Article 33 breach assessment · Lead Data Privacy Officer · 6 July 2026

No forensic analysis and no Article 33 assessment were performed on the ~1,200 adversarial queries that executed through the full transformer stack during MDC-2026-8891. Sources: §4.1, ADV-02, ADV-03, GAP-05.

Residual after control: the 72-hour clock has already run. Awareness dates from the alert, within the last 90 days. If the incident was notifiable, the deadline passed unnoticed and cannot be recovered — only mitigated by prompt late notification with documented reasons under Article 33(1). Forensic reconstruction may also prove inconclusive if telemetry granularity is insufficient, in which case the inability to determine the outcome is itself the finding to record.

RSK-04 — Article 22 position unevidenced · AI Governance Lead · 17 July 2026

The package asserts that outputs influence but do not solely determine claim outcomes. No review rate, override rate or reviewer authority matrix exists. The system is the sole screening layer, dispatches transactional instructions rather than recommendations, and red-teamers bypassed routing to review in 14.2% of variations. Sources: GAP-05, OD-03, ADV-03, DID-05.

Residual after control: instrumentation makes the answer visible; it does not make it favourable. If measurement shows review is nominal, Article 22(1) applies to automated decisions on special category data, Article 22(4) restricts the available grounds, and the lawfulness of the processing itself is in question. This is the item that can change the audit verdict to a pause recommendation. Automation bias is separately untouched — concordance is not evidence of independent judgement.

A.3 Items closed by correction during this review

Recorded so that no upstream finding disappears without disposition. Thirteen defects in the supplied source pack were corrected before analysis, rather than absorbed silently.

Item	Disposition
Article 9 misclassification across three records	Corrected in the RoPA. P-01, P-05 and P-06 reclassified to Article 9 with reasoning recorded in the Lawful Basis worksheet.
Article 30(1)(a), (e), (g) omissions	Three columns added. The security-measures column records applied controls and known deficiencies.
Six unregistered processing activities	Registered as P-02, P-03, P-07, P-08, P-09 and P-10. The register now covers ten activities.
DP-SGD pointed at the wrong object	Re-pointed: NER masking protects the export, DP-SGD protects the model. Implementation tracked at RSK-07 and RSK-09.
EDPB anonymisation overclaim	Removed. Section 2.3 now states the corpus remains personal data under Article 4(5).
C2.2 status contradiction	Corrected to Non-Compliant on three-way corroboration. Compliance score restated from 55.6% to 25.0%.
AS-02 and AS-05 missing from the attack surface map	Both restored. AS-05 separated from AS-03, resolving the conflation that left the training pipeline without a surface.
Wrong CVE in two artifacts	CVE-2026-38291 withdrawn. Decision matrix and rollback plan rewritten against CVE-2025-XXXX.
Decision matrix recommended a non-winning strategy	Rescored for training-time exposure; Hybrid now scores highest at 3.90, and a mandatory gate test excludes patch-only regardless of rank.
Inherited compensating control unworkable	Replaced with CC-1 shadow comparator, CC-2 distribution monitoring, CC-3 review sampling, CC-4 forward closure.
Rollback trigger self-defeating at 92.5%	Corrected to 89.5%, below the rollback target's 90.4% so reverting does not re-trigger.
Rollback had no CVE-detecting trigger	Trigger 3 added — shadow comparator divergence.
Rollback 24-hour cap unworkable	Escalation path defined in MHP-OPSC-RECOVERY-v2 §5 for any rollback persisting beyond 24 hours.

A.4 Open determinations

Not risks — unknowns. Recorded as unresolved rather than assumed, because an assumed answer that proves wrong is worse than a declared gap.

Ref	Question	Owner / due	Bears on
OD-01	Main establishment and lead supervisory authority	Lead DPO · 17 Jul	Article 9(2)(g) basis for 8 of 10 records; Article 56 routing
OD-02	Country of establishment of NovaTriage Analytics Ltd.	Lead DPO · 10 Jul	RSK-07, RSK-08. Corpus export suspended pending the answer, which delays the RSK-02 retrain
OD-03	Measured review rate, override rate, reviewer authority	AI Governance Lead · 17 Jul	RSK-04 — and the audit verdict. See Section 1.5
OD-04	Azure region and Microsoft sub-processor chain	CISO · 17 Jul	RSK-08; RoPA P-09 telemetry transfers
OD-05	Identity of the non-EU jurisdictions	Lead DPO · 31 Jul	Regime mapping; register completeness for non-EU processing
OD-06	AI Act Annex III negative determination documented	AI Governance Lead · 31 Aug	Scoped out of this package; a system determining clinical gravity will attract the question
OD-07	Is ethnicity a model input feature or a monitoring dimension?	AI Governance Lead · 17 Jul	RSK-14; RoPA P-04. If an input feature, direct discrimination risk under Article 5(1)(a)
OD-08	Was MDC-2026-8891 authorised red-team traffic?	SecOps Incident Commander · 6 Jul	RSK-03. Must be answered before the Article 33 assessment concludes

Ref	Question	Owner / due	Bears on
OD-09	Full 90-day alert inventory and volume baseline	SecOps Incident Commander · 10 Jul	RSK-03, RSK-05. Without it, a one-off and a sustained pattern look identical

Part B — Integration Consistency Statement

The clearest cross-section evidence link in this package runs from Model Security into GDPR Compliance by way of the Risk Disposition, and it is the link that makes the privacy and security halves of this assessment inseparable.

Section 3.2 records adversarial finding ADV-03: exploiting token logit distributions forced the output decoding layer to append standard-processing routing tags to high-risk claims, bypassing the human review trigger. Section 2.2 records DPIA gap GAP-05: the deployment's entire Article 22 position rests on human review of flagged claims being meaningful. The routing that ADV-03 defeats is the safeguard GAP-05 depends on. A model security finding is therefore load-bearing for a privacy conclusion, and neither section can be read correctly on its own.

Verification ran in both directions. Forward: ADV-03 appears in Section 3.2 at severity CRITICAL, maps to attack surface AS-04 in Section 3.1, and appears in Part A as RSK-01 with the Application Security Lead named and a 4 July 2026 close date. Backward: the source field of RSK-01 cites AS-04, ADV-03, DID-02, DID-05 and HP-01, and each was confirmed present in Section 3 at the stated severity. The connection into Section 2 was verified by checking that control C2.5, routing decision integrity verification, appears both as the technical remediation in Section 3.3 and as the evidential control GAP-05 requires — carrying the same control identifier in both places.

The same bidirectional test was applied across all forty-six tracked findings. No orphan was found in either direction.

Part B (continued) — Integration consistency check results

Six checks were run against the assembled document rather than asserted from memory.

Check	Result	Evidence
Deployment scope described consistently across all five sections	PASS	Every section names Insurance Claims Triage AI (ClaimsTriage) v2.4 and the sole-screening-layer characteristic. Eight superseded identifiers were tested for and appear nowhere except where the package explicitly records them as withdrawn: "Contoso", CVE-2026-38291, the 92.5% threshold, "v1.4.2-stable", the 12-minute recovery SLA, "card-network", "SLA ceiling floor" and "Virtual Triage Assistant".
Every open item in the Risk Disposition traces to an analysis in an earlier section	PASS	All twenty risk IDs appear in Sections 1–4, and each carries a source field citing the upstream finding. Reverse-tested: all twenty-four upstream finding identifiers (GAP-01 to GAP-07, ADV-01 to ADV-03, DID-01 to DID-09, R-DEID-01 to R-DEID-05) are cited in Part A.
Attack surface in Model Security matches the surface implicated by the Defender alert	PASS	Sections 3 and 4 name the identical surface set AS-01 to AS-05. No surface is introduced in Section 4 that does not exist in Section 3. MDC-2026-8891 decomposes to AS-01 ("anomalous token sequences"), AS-02 ("repeated high-entropy inputs") and AS-03/AS-04 ("application-layer routing bypasses"), each named in Section 3 before the telemetry was read.
The CVE documented in Operational Security appears as a named risk	PASS	CVE-2025-XXXX is named in Sections 1, 4 and 5, and carried as RSK-02 with the Director of AI Production Infrastructure Operations as owner, a patch date of 3 July and a retrain completion date of 31 July 2026.
Executive Summary verdict defensible given the open items	PASS	Four CRITICAL risks stand open, so the verdict is NOT READY IN CURRENT STATE. The top three priorities are drawn from Part A rather than generated independently, and Section 1.5 states the single determination (OD-03) that would move the recommendation to a pause.
Appendix contains a completed GenAI Audit Trail or signed Non-Use Attestation	PASS	Appendix A is a completed GenAI Audit Trail. The template's pre-written Non-Use Governance Attestation was removed and its removal disclosed, because a generative assistant was used and signing that attestation would have been a false statement in an audit document.

Two defects were found by this check and corrected before submission, which is the reason for running it against the assembled document rather than from memory. First, the version identifier v2.4 was absent from the bodies of Sections 1 and 2 — a scope anchor present in the title block but not in the narrative. Second, the risk register

carried no source column, so eighteen upstream finding identifiers were traceable forward but not backward. Both are closed above.

Appendix A — GenAI Audit Trail

This appendix replaces the Non-Use Governance Attestation supplied in the report template. A generative AI assistant was used in preparing this package, and the template's pre-written attestation — that no automated generative workflows were utilised — would have been a false statement signed in an audit document. An accurate disclosure is given instead.

Tool used	Commercial general-purpose generative AI assistant with session audit trail, operated by the AI Governance Lead.
Scope of use	Drafting and structuring of narrative sections; cross-artifact consistency checking; construction of the risk disposition register, traceability matrix and supporting workbooks; arithmetic verification of figures derived from stated baselines.
What the tool did NOT do	No figure, threshold, severity rating or legal basis in this package originates with the tool. Every quantitative value is either stated in the scenario package or derived arithmetically from stated values, and each derivation is shown in the supporting artifact where it appears.
Human verification performed	All Article 6 and Article 9 determinations reviewed and confirmed by the AI Governance Lead. All severity ratings reconciled against the Prompt-Injection Triage Rubric and against the independent adversarial test report. All arithmetic re-computed from source baselines. All corrections to supplied artifacts recorded in per-artifact change logs with the primary source cited.
Corrections made to tool output	Attack surface severities were revised downward after reconciliation with MHP-ADV-REP-2026-v1: the initial assessment rated AS-01 CRITICAL by crediting downstream enablement, which inflates every upstream surface. The red team's direct-impact scoring was adopted, reducing three gap severities from CRITICAL to HIGH. Hardening priorities were likewise revised to follow the red team's selection rather than the initial draft's.
Residual reliance	The interpretive judgements in this package — the Article 9 reclassifications, the Article 22 position, the audit readiness verdict — are the professional determinations of the AI Governance Lead and are owned as such.

Signed: AI Governance Lead, Meridian Health Partners Ltd. — 3 July 2026

Appendix B — Source Pack Reconciliation

The supplied source pack contained artifacts that contradicted one another and the scenario package. Analysis could not proceed until a single canon was established. This appendix records it, so that an auditor comparing this package against the supplied templates can see what changed and why.

Item	Canon adopted	Overrides
Entity	Meridian Health Partners Ltd.	"Contoso Health Partners" in the scenario header, the RoPA controller field and all workbook titles. Matches the MHP- document reference prefix and the inline narrative.
Vulnerability	CVE-2025-XXXX — training-time, CVSS 8.6	CVE-2026-38291 (tokenizer RCE, CVSS 9.1) in the decision matrix and rollback plan, withdrawn entirely.
Accuracy thresholds	94.2% current · 91.0% SLA floor · 90.4% rollback target · 89.5% rollback trigger	The 92.5% threshold in the rollback plan and decision matrix, which would have caused the rollback target to breach its own trigger on execution.
Rollback target	ClaimsTriage v2.3 on NeuralCore v2.9.1, 45 minutes	"v1.4.2-stable", 12 minutes.
Article 9, claim narratives	Yes — Article 9(2)(g)	The supplied workbook contradicted itself between its own two tabs.
DPIA reference	DPIA-VTA-2024-003	"DPIA-MHP-003" in scenario §2.2.
Attack surfaces	AS-01 to AS-05, five surfaces	Three incompatible schemes: AN-SURF-01 to 04, three generic names, and VUL-TOK-01/ATT-03/DEC-04 with a numbering gap.

Item	Canon adopted	Overrides
Rubric method	Section 3 matrix — feasibility crossed with impact	Section 2's consequence-only classification, which returns different severities. The choice is recorded so a reviewer reaching a different figure sees why.
Appendix	GenAI Audit Trail	The template's Non-Use Governance Attestation, which would have been inaccurate.

Thirteen individual defects were corrected. Each is recorded in the change log of the artifact it affected, with the primary source cited. None was absorbed silently.

Appendix C — Supporting Artifacts

Artifact	Contents
RoPA — Article 30 Register	Ten processing activities across twenty columns; lawful basis classification worksheet; twenty-five-element Article 9 field inventory; open determinations; register summary; change log.
DPIA Mitigation Plan	Seven gaps across six mitigation categories, each with named control, owner, effectiveness criterion, review cadence and residual risk; gap-detection methodology including the added completeness step.
De-Identification Comparison Matrix	Four-technique comparison; hybrid recommendation with deployment-specific justification; five residual risks stated for acceptance; the DP-SGD correction.
Transformer Attack Surface Report	Five surfaces with threat vectors, control coverage, evidence basis and rubric scoring; adversarial findings ledger; three hardening priorities with staged remediation.
Defence-in-Depth Control Checklist	Twelve controls across three layers; nine identified gaps with rubric severity and adversarial traceability; layer crosswalk; dashboard; change log.
Patch-vs-Retrain Decision Matrix	Rescored evaluation matrix; mandatory gate test; decision summary with signed risk acceptance; business impact model.
Emergency Rollback Plan (MHP-OPSC-RECOVERY-v2)	Four trigger conditions including the added shadow-comparator divergence; state preservation; execution runbook; residual exposure and the beyond-24-hour escalation path.
Unified Risk Disposition Register	Twenty risks with control, owner, target date and residual; forty-six-item traceability matrix; nine open determinations.

End of report. Prepared by the AI Governance Lead, Meridian Health Partners Ltd., 3 July 2026.